

Modelo de Encuesta Integral NIST CSF 2.0

Aplicación a organizaciones en España (sector público y privado)

Objetivo: Recoger información estructurada sobre la adopción, madurez y métricas asociadas al NIST CSF 2.0 (o marcos equivalentes) en organizaciones españolas, con foco en indicadores de gobernanza, riesgo, operación y resiliencia.

0. Datos generales de la organización

0.1. Tipo de organización

- ☐ Administración pública (AGE, CCAA, EELL)
- ☐ Organismo público independiente / Agencia
- ☐ Operador de servicios esenciales (OES, NIS/NIS2)
- ☐ Entidad financiera / crítica (DORA)
- ☐ Empresa privada grande (> 250 empleados)
- ☐ PYME tecnológica / digital
- ☐ Otro (especificar): _____

0.2. Sector principal de actividad

- ☐ Administración / servicios públicos
- ☐ Salud
- ☐ Energía
- ☐ Transporte y logística
- ☐ Finanzas / seguros
- ☐ Industria / manufactura / OT
- ☐ Telecomunicaciones
- ☐ TIC / servicios digitales
- ☐ Educación / universidad / I+D
- ☐ Otros: _____

0.3. Tamaño aproximado

- ☐ < 50 empleados
- ☐ 50–249 empleados
- ☐ 250–999 empleados
- ☐ 1 000–4 999 empleados
- ☐ ≥ 5 000 empleados

0.4. Rol de la persona que responde

- ☐ CISO / Director de Seguridad de la Información
- ☐ Responsable de TI / CIO
- ☐ Responsable de Continuidad / Riesgos
- ☐ Responsable de Cumplimiento / Auditoría / DPO
- ☐ Dirección General / CEO / Gerencia
- ☐ Otro (especificar): _____

1. GOVERN (GV) – Estrategia, gobierno y apetito de riesgo

1.1. Estrategia y objetivos de ciberseguridad

P-GV-01. ¿Dispone la organización de una estrategia formal de ciberseguridad o documento equivalente aprobado por la alta dirección o el órgano de gobierno?

- ☐ No existe tal documento; confiamos en el orden espontáneo.
- ☐ Existe en borrador, con cierta vocación de convertirse en realidad.
- ☐ Existe y está aprobado, pero se revisa de forma esporádica.
- ☐ Existe, está aprobado y se revisa al menos cada 2 años con datos objetivos.
- ☐ Existe, se revisa al menos anualmente y se alinea con planes y presupuestos.

P-GV-02. ¿En qué medida los objetivos de ciberseguridad están formulados con métricas claras (KPIs/KRIs) asociadas?

- ☐ Prácticamente nada: los objetivos son frases inspiracionales.
- ☐ Algunos objetivos tienen métricas, pero su seguimiento es ocasional.
- ☐ La mayoría de los objetivos clave tienen métricas y se revisan al menos anualmente.
- ☐ Los objetivos se formulan sistemáticamente con métricas, revisadas periódicamente y usadas en la toma de decisiones.

P-GV-03. Frecuencia de revisión de la estrategia de ciberseguridad

- ☐ Solo después de un susto épico (incidente grave, auditoría demoledora).
- ☐ Menos de una vez cada 3 años.
- ☐ Cada 2–3 años, de forma razonablemente estructurada.
- ☐ Al menos una vez al año, incorporando lecciones aprendidas e indicadores.
- ☐ Revisión continua, con ajustes frecuentes sobre la base de datos y evolución de riesgos.

1.2. Apetito y tolerancia al riesgo

P-GV-04. ¿La organización dispone de una declaración formal de apetito de riesgo en materia de ciberseguridad?

- ☐ No; el apetito de riesgo se intuye por el tamaño de las brechas.
- ☐ Existe una declaración general, sin detalles específicos de ciberseguridad.
- ☐ Existe una declaración específica para ciberriesgo, pero poco conocida.
- ☐ Existe, es comunicada y se traduce en límites y criterios operativos (p.ej., umbrales de riesgo aceptable).

P-GV-05. ¿Cómo se utiliza la declaración de apetito de riesgo en la práctica? (respuesta múltiple)

- ☐ Se utiliza para decidir sobre inversiones en seguridad.
- ☐ Se utiliza para priorizar proyectos / iniciativas de mitigación.
- ☐ Se integra en el proceso de gestión de riesgos corporativo.
- ☐ Se utiliza para aprobar o rechazar excepciones de seguridad.
- ☐ No se utiliza de forma explícita (es más un cuadro en la pared que una herramienta de trabajo).

1.3. Roles, responsabilidades y supervisión

P-GV-06. ¿Existe un responsable de ciberseguridad formalmente designado con responsabilidad global (CISO o equivalente)?

- ☐ No, la seguridad es un deporte parcialmente voluntario.
- ☐ Sí, pero el rol se combina con otros (p.ej., responsable de TI).
- ☐ Sí, rol diferenciado, con mandato explícito y autoridad suficiente.

P-GV-07. ¿Con qué frecuencia se informa a la alta dirección / consejo sobre el estado de la ciberseguridad?

- ☐ Solo después de incidentes graves o auditorías.
- ☐ Anualmente, de forma sumaria.
- ☐ Trimestralmente o similar, con indicadores estructurados.
- ☐ Mensualmente o casi, con KPIs/KRIs y planes de acción.

P-GV-08. ¿Estos informes incluyen indicadores cuantitativos (KPIs/KRIs) alineados con NIST CSF o marcos equivalentes?

- ☐ No, se basan en texto narrativo y anécdotas heroicas.
- ☐ Incluyen algunos datos, pero sin estructura de marco de referencia.
- ☐ Incluyen un conjunto estable de KPIs/KRIs agrupados por dominios (gobernanza, riesgo, operación, resiliencia).
- ☐ Están mapeados explícitamente al NIST CSF (u otro marco estructurado) y se utilizan para evaluar la madurez.

2. IDENTIFY (ID) – Activos, datos, contexto y riesgo

2.1. Inventario de activos

P-ID-01. ¿En qué medida dispone la organización de un inventario actualizado de activos (IT, OT, IoT, nube)?

- ☐ No existe inventario o está tan desactualizado que vale más la intuición.
- ☐ Inventario parcial, mantenido manualmente, con lag temporal significativo.
- ☐ Inventario razonablemente completo, con apoyo de herramientas pero con huecos.
- ☐ Inventario casi completo, automatizado y con procesos de actualización fiables.

P-ID-02. Estimación del grado de cobertura del inventario automatizado

- ☐ < 50 % de los activos estimados.
- ☐ 50–80 %.
- ☐ 81–95 %.
- ☐ > 95 %, con descubrimiento continuo.

2.2. Datos y clasificación

P-ID-03. ¿Se encuentran los datos clave (PII, datos financieros, datos OT, propiedad intelectual) identificados y clasificados?

- ☐ No, los datos fluyen libremente como novelas por entregas.
- ☐ Parcialmente, en sistemas más críticos o regulados.
- ☐ Mayoritariamente, con clasificación coherente y propietarios de datos asignados.
- ☐ Sí, y la clasificación se usa activamente para definir controles, políticas y monitorización.

P-ID-04. ¿Qué porcentaje de repositorios críticos de datos cuentan con propietario formalmente designado?

- ☐ < 25 %.
- ☐ 25–50 %.
- ☐ 51–75 %.
- ☐ > 75 %.

2.3. Gestión de riesgo

P-ID-05. ¿Qué enfoque predomina en la evaluación de riesgos de ciberseguridad?

- ☐ Evaluaciones ad hoc, sin método consistente (épica y buen juicio).
- ☐ Método cualitativo informal (alto/medio/bajo), sin integración con ERM.
- ☐ Método cualitativo estructurado integrado con ERM corporativo.
- ☐ Método cuantitativo o semi-cuantitativo, con agregación de pérdidas esperadas y escenarios.

P-ID-06. ¿Cuál es la periodicidad habitual de las evaluaciones de riesgo de ciberseguridad sobre sistemas y procesos críticos?

- ☐ Solo cuando se incorpora un nuevo sistema o tras un incidente grave.
- ☐ Menos de una vez cada 3 años.
- ☐ Cada 1–2 años.
- ☐ Al menos anual, con revisiones adicionales cuando cambian amenazas o tecnología.

P-ID-07. ¿En qué medida el registro de riesgos corporativo incluye riesgos de ciberseguridad claramente identificados y vinculados a activos y procesos?

- ☐ No existen entradas específicas de ciberriesgo.
- ☐ Existen algunas entradas genéricas.
- ☐ La mayoría de los riesgos ciber relevantes están descritos con cierto nivel de detalle.
- ☐ Existe un mapa detallado de riesgos ciber, con prioridades, dueños y planes asociados.

3. PROTECT (PR) – Controles preventivos, acceso, formación y tecnología

3.1. Gestión de identidades y accesos

P-PR-01. Cobertura de autenticación multifactor (MFA) en cuentas de alto riesgo

Para cuentas administrativas, acceso remoto, aplicaciones críticas:

- ☐ < 25 % (la contraseña todavía reina).
- ☐ 25–75 % (en transición, con batallas culturales en curso).
- ☐ > 75 % (solo quedan algunos sistemas históricos resistiéndose).
- ☐ ~100 % (casi utopía zero trust).

P-PR-02. Gestión del ciclo de vida de identidades

- ☐ Alta, modificación y baja de usuarios gestionada principalmente de forma manual y sin seguimiento sistemático.
- ☐ Procesos definidos, pero con ejecución irregular y controles limitados.
- ☐ Procesos definidos, con cierto grado de automatización y revisiones periódicas.
- ☐ Procesos altamente automatizados, integrados con RRHH y revisados con auditorías regulares.

3.2. Concienciación y cultura

P-PR-03. Programa de concienciación en ciberseguridad

- ☐ No existe un programa formal; se confía en el instinto de supervivencia.
- ☐ Se realizan acciones puntuales (charlas, correos, carteles).
- ☐ Programa estructurado anual, con contenidos diferenciados por perfiles.
- ☐ Programa continuo, con campañas periódicas, contenidos adaptados y métricas de efectividad.

P-PR-04. Simulaciones de phishing u otros ejercicios de ingeniería social

- ☐ No se realizan; preferimos no tentar a la suerte.
- ☐ Se realizan ocasionalmente, sin explotación sistemática de resultados.
- ☐ Se realizan al menos anualmente, con análisis de tasas de clic y refuerzo formativo.
- ☐ Se realizan múltiples veces al año, segmentados por colectivos, con reducción observada de errores.

3.3. Protección de datos y plataformas

P-PR-05. Protección de datos sensibles (cifrado, DLP, controles de acceso)

- ☐ No existe una política clara ni controles específicos.
- ☐ Hay políticas y algunos controles básicos (cifrado en tránsito, accesos controlados).
- ☐ Controles establecidos (cifrado en reposo, segmentación, DLP limitada) y aplicados a sistemas clave.
- ☐ Enfoque integral: cifrado generalizado, DLP maduro, controles adaptativos y monitorización.

P-PR-06. Gestión de parches y actualizaciones

- ☐ No hay política formal; se parchea “cuando se puede”.
- ☐ Política definida, pero con cumplimiento irregular.
- ☐ Política aplicada con prioridad a activos críticos, tiempos definidos por riesgo.
- ☐ Gestión sistemática basada en riesgo, con métricas de tiempo medio de parcheo y objetivos claros.

4. DETECT (DE) – Monitorización, detección y análisis

4.1. Cobertura de monitorización

P-DE-01. Cobertura de registro y monitorización de activos críticos

- ☐ Muy limitada; solo algunos sistemas generan logs útiles.
- ☐ Cobertura parcial de sistemas críticos en una o varias herramientas.
- ☐ Amplia cobertura de sistemas críticos, con integración en SIEM u otras plataformas.
- ☐ Cobertura muy alta, incluyendo tráfico de red, endpoints, nube y OT, con correlación centralizada.

P-DE-02. Integración de inteligencia de amenazas (Threat Intelligence)

- ☐ No se utiliza información externa de amenazas.
- ☐ Se consultan fuentes externas de forma manual y puntual.
- ☐ Se usan fuentes externas básicas integradas parcialmente en herramientas.
- ☐ Fuentes múltiples (públicas, sectoriales, comerciales) integradas en procesos y herramientas de detección.

4.2. Métricas de detección

P-DE-03. ¿Se mide el tiempo medio de detección (MTTD) de incidentes?

- ☐ No, el reloj se activa más bien tarde.
- ☐ Se mide ocasionalmente, tras incidentes relevantes.
- ☐ Se mide de forma sistemática pero con uso limitado en la gestión.
- ☐ Se mide, se reporta a la dirección y se usa para objetivos de mejora continuos.

5. RESPOND (RS) – Respuesta a incidentes y comunicación

5.1. Planes de respuesta a incidentes

P-RS-01. Existencia de plan de respuesta a incidentes

- ☐ No existe; la respuesta es esencialmente improvisada.
- ☐ Existe en borrador o para algunos sistemas críticos.
- ☐ Existe plan general con roles definidos, pero la práctica es limitada.
- ☐ Planes actualizados, probados regularmente y con lecciones aprendidas incorporadas.

P-RS-02. ¿Con qué frecuencia se realizan ejercicios o simulacros de respuesta a incidentes?

- ☐ Nunca; el incidente real será nuestro primer ejercicio.
- ☐ Menos de una vez cada 2 años.
- ☐ Al menos cada 2 años, con participación de áreas clave.
- ☐ Anualmente o más, con participación de dirección y terceros relevantes.

5.2. Métricas de respuesta

P-RS-03. ¿Se mide el tiempo medio hasta la contención de incidentes graves?

- ☐ No, la memoria colectiva es el único “métrico” disponible.
- ☐ Se estima para algunos incidentes, pero sin registro estructurado.
- ☐ Se registra y se analiza para identificar mejoras.
- ☐ Se registra, se consolida en KPIs y se reporta a dirección como objetivo de mejora.

P-RS-04. ¿Qué grado de formalización tienen los procesos de comunicación de incidentes a autoridades y terceros?

- ☐ No hay proceso definido; se reacciona caso por caso.
- ☐ Existen pautas generales, con cierta guía de plazos (GDPR, NIS, etc.).
- ☐ Procesos documentados y conocidos, con responsables claros y plantillas.
- ☐ Procesos probados, integrados con requisitos regulatorios y con métricas de cumplimiento de plazos.

6. RECOVER (RC) – Continuidad, recuperación y resiliencia

6.1. Objetivos de recuperación

P-RC-01. ¿Están definidos objetivos de RTO/RPO para procesos y sistemas críticos?

- ☐ No; la esperanza es la estrategia predominante.
- ☐ Definidos para algunos sistemas o procesos.
- ☐ Definidos para la mayoría de procesos críticos.
- ☐ Definidos, priorizados y alineados con las expectativas de negocio y reguladores.

P-RC-02. ¿Con qué frecuencia se prueban los planes de continuidad y recuperación?

- ☐ No se prueban.
- ☐ Esporádicamente, y solo a nivel de backup restaurado en laboratorio.
- ☐ Al menos una vez al año para sistemas críticos, con escenarios realistas.
- ☐ Con frecuencia, incluyendo pruebas integrales con participación de proveedores y terceros.

6.2. Métricas de resiliencia

P-RC-03. En el último ejercicio de recuperación, ¿qué porcentaje de servicios alcanzó el RTO definido?

- ☐ No se realizaron ejercicios.
- ☐ Menos de la mitad.
- ☐ Entre la mitad y tres cuartas partes.
- ☐ La mayoría o todos, con evidencias documentadas.

7. Cadena de suministro y terceros (GV.SC)

P-SC-01. Inventario y clasificación de proveedores según criticidad

- ☐ No hay inventario completo de proveedores TIC/estratégicos.
- ☐ Existe inventario básico sin clasificación por criticidad.
- ☐ Inventario con clasificación básica (crítico/no crítico).
- ☐ Inventario con criterios definidos (tipo de datos, acceso, impacto, dependencia), revisado periódicamente.

P-SC-02. Requisitos de ciberseguridad en contratos con proveedores críticos

- ☐ No se incluyen cláusulas específicas de seguridad.
- ☐ Se incluyen cláusulas generales, no siempre verificadas.
- ☐ Se incluyen cláusulas específicas (notificación de incidentes, estándares mínimos, etc.), y se revisan al menos en la firma.
- ☐ Cláusulas detalladas, revisadas, con mecanismos de verificación y métricas de cumplimiento.

P-SC-03. Evaluación periódica de seguridad de proveedores críticos

- ☐ No se realizan evaluaciones.
- ☐ Evaluaciones puntuales o solo tras incidentes.
- ☐ Evaluaciones periódicas (2-3 años) para proveedores críticos.
- ☐ Evaluaciones al menos anuales, con evidencias, auditorías y planes de mejora.

8. Métricas, cuadros de mando y ROI

P-ME-01. ¿Dispone la organización de un cuadro de mando de ciberseguridad con indicadores cuantitativos?

- ☐ No, vivimos en la narrativa y la anécdota.
- ☐ Sí, pero disperso y sin estructura homogénea.
- ☐ Sí, con indicadores organizados por dominios (gobernanza, riesgo, operación, resiliencia).
- ☐ Sí, alineado con NIST CSF (u otro marco) y usado regularmente por la alta dirección.

P-ME-02. ¿Se calcula algún índice de madurez (p.ej., por función NIST CSF) en la organización?

- ☐ No se calcula formalmente.
- ☐ Se manejan percepciones cualitativas sin escala definida.
- ☐ Se utiliza una escala interna (p.ej., 1-4 o 1-5) ligada a niveles de madurez.
- ☐ Se utiliza una escala definida de madurez (p.ej., Tiers NIST, CMMI, etc.) con evaluaciones periódicas.

P-ME-03. ¿Se evalúa el retorno de la inversión (ROI) de las iniciativas de ciberseguridad?

- ☐ No; se asume que “hay que hacerlo” y ya.
- ☐ Se utilizan estimaciones ocasionales para grandes proyectos.
- ☐ Se analizan costes, riesgos y beneficios esperados de forma sistemática en los proyectos clave.
- ☐ Existen modelos formales o semi-formales de análisis de ROI o de reducción de riesgo monetizada.

9. Comentarios abiertos

P-AB-01. Desde su experiencia, ¿cuál es la mayor barrera para mejorar sus indicadores y métricas de ciberseguridad?

(respuesta abierta)

P-AB-02. ¿Qué indicador o métrica le gustaría poder reportar dentro de 2 años que hoy todavía no domina?

(respuesta abierta)

Fin de la encuesta. Muchas gracias por su contribución lúcida a la causa ciber.